COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.3 · Third-party Risk Assessment

Mestre CyberSec · **Aula 5.3 — Third-party Risk Assessment** (11:36) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** TPRM: right-to-audit clause (contrato DEIXA tu auditar); supply chain analysis (quem fornece o fornecedor); vendor monitoring (a postura de segurança continuamente).

💡 Highlights que a prova CompTIA cobra

- TPRM: avaliar, contratar, MONITORAR o fornecedor continuamente
- Right-to-audit: cláusula que deixa tu auditar o fornecedor

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'contract clause allowing security audits of vendor'=right-to-audit

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.3 — Third-party Risk Assessment)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Gestão de Riscos de Terceiros (TPRM)

Estrutura formal usada para identificar, avaliar, mitigar e monitorar continuamente os riscos introduzidos por fornecedores, prestadores de serviços e terceiros que acessam dados ou sistemas da organização.

⚠ ***Armadilha CompTIA:*** *TPRM is NOT a one-time event. The CompTIA exam expects you to know the full lifecycle: due diligence before contracting, contract clauses during onboarding, and continuous MONITORING after signing.*

• Cláusula de Direito de Auditoria (N/A)

Cláusula contratual que concede ao cliente o direito legal de auditar os controles de segurança, processos e postura de conformidade do fornecedor, geralmente com frequência, escopo e prazo de aviso definidos.

⚠ ***Armadilha CompTIA:*** *When a question mentions 'contract clause allowing security audits of vendor' → right-to-audit. This must be negotiated BEFORE signing; without it, the vendor can legally refuse your audit request.*

• Análise da Cadeia de Suprimentos (N/A)

Processo de avaliar não apenas o fornecedor direto, mas também seus fornecedores upstream, subcontratados e dependências (o fornecedor do fornecedor) para identificar riscos ocultos e pontos únicos de falha.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'risks introduced by a vendor's upstream provider' = supply chain analysis. Think SolarWinds/Sunburst — the breach happened at a 4th-party, not the direct vendor.*

• Monitoramento de Fornecedores (N/A)

Avaliação contínua e permanente da postura de segurança de um fornecedor após a assinatura do contrato, usando ferramentas como ratings de segurança, relatórios de auditoria, feeds de inteligência de ameaças e atestações de conformidade.

⚠ ***Armadilha CompTIA:*** *Vendor monitoring = POST-contract, CONTINUOUS activity. Do not confuse with due diligence (pre-contract) or right-to-audit (periodic on-demand review). Monitoring is automated and ongoing.*

• Diligência Devida (Due Diligence) (N/A)

Investigação pré-contratual e avaliação de risco realizada em um fornecedor potencial para verificar sua postura de segurança, estabilidade financeira, status de conformidade e capacidade de atender aos requisitos contratuais.

⚠ ***Armadilha CompTIA:*** *Due diligence happens BEFORE signing the contract. If a question places this activity AFTER onboarding, it's vendor monitoring, not due diligence. Also applies to M&A scenarios.*

• Controle de Organização de Serviços 2 (SOC 2)

Relatório de auditoria independente de terceiros (Tipo I ou Tipo II) que avalia os controles de um prestador de serviços contra os Trust Services Criteria: segurança, disponibilidade, integridade de processamento, confidencialidade e privacidade.

⚠️ ***Armadilha CompTIA:*** *SOC 2 Type I = controls at a POINT IN TIME; SOC 2 Type II = controls over a PERIOD (typically 6-12 months). CompTIA prefers Type II for stronger assurance. Look for this in vendor assessment questions.*

• Avaliação de Risco de Fornecedor (N/A)

Avaliação formal que classifica fornecedores por criticidade (ex.: tier 1, 2, 3) com base no acesso a dados, integração de sistemas e impacto no negócio, atribuindo controles de segurança e frequência de revisão correspondentes.

⚠️ ***Armadilha CompTIA:*** *Not all vendors are equal: a vendor handling PII gets deep assessment + right-to-audit + continuous monitoring; a coffee supplier gets minimal review. Exam questions test tiered/risk-based approach.*

• Acordo de Confidencialidade (NDA)

Contrato legal vinculante entre a organização e um fornecedor que define informações confidenciais, restringe sua divulgação e estabelece penalidades por violação durante e após a relação comercial.

⚠️ ***Armadilha CompTIA:*** *NDAs protect confidentiality but do NOT guarantee security. On the exam, an NDA alone is NEVER sufficient risk mitigation — it must be combined with due diligence, right-to-audit, and monitoring controls.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa está finalizando um contrato com um provedor SaaS crítico que processará dados regulamentados de clientes. O jurídico quer garantir que a empresa possa verificar os controles de segurança do provedor ao longo do tempo. Qual cláusula contratual atende melhor a esse requisito?

A) Cláusula de direito de auditoria

B) Acordo de confidencialidade

C) Acordo de nível de serviço com garantias de disponibilidade

D) Cronograma de retenção de dados

QUESTÃO 2 · CENÁRIO DE EXAME

Um fornecedor terceiriza o processamento de dados para um subprocessador em nuvem. O relatório SOC 2 do fornecedor principal não menciona esse subprocessador. O que a equipe de segurança deve fazer primeiro?

A) Avaliar o subprocessador como risco de quarta parte e solicitar evidências de seus controles

B) Aceitar o relatório SOC 2 do fornecedor principal como suficiente

C) Encerrar o contrato imediatamente

D) Pedir que o fornecedor principal assine um acordo de confidencialidade

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa usa um fornecedor crítico de pagamentos. A equipe de segurança quer detectar mudanças na postura de segurança do fornecedor entre revisões anuais. Qual atividade contínua é mais apropriada?

A) Depender indefinidamente da avaliação de due diligence inicial

B) Monitorar notificações de violação, classificações de segurança e atestados atualizados do fornecedor

C) Realizar testes de penetração não autorizados contra o fornecedor

D) Exigir que o fornecedor envie apenas relatórios mensais de disponibilidade

QUESTÃO 4 · CENÁRIO DE EXAME

Durante a due diligence, um analista de segurança revisa o relatório SOC 2 Tipo II de um fornecedor. Em quais elementos o analista deve se concentrar mais?

A) Preço das ações e receita anual do fornecedor

B) Tamanho da equipe de vendas do fornecedor

C) Escopo, período de auditoria, exceções e controles complementares da entidade usuária

D) Duração do contrato padrão do fornecedor

QUESTÃO 5 · CENÁRIO DE EXAME

Antes de compartilhar diagramas de rede e planos de resposta a incidentes com um provedor de serviços de segurança gerenciados em potencial durante uma avaliação, qual acordo é mais apropriado?

A) Cláusula de direito de auditoria

B) Acordo de confidencialidade

C) Relatório SOC 2 Tipo II

D) Análise de impacto nos negócios

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa tem centenas de fornecedores terceirizados e recursos limitados de avaliação. Qual fator deve determinar mais diretamente a profundidade da avaliação de risco para cada fornecedor?

A) Proximidade do fornecedor à sede da empresa

B) Número de anos que o fornecedor está no mercado

C) Condições de pagamento e taxa de desconto do fornecedor

D) Nível de acesso a dados sensíveis e criticidade para o negócio

QUESTÃO 7 · CENÁRIO DE EXAME

O software de gerenciamento de um fornecedor de hardware inclui uma biblioteca de código aberto de terceiros com uma vulnerabilidade crítica. O que a organização deve fazer primeiro?

A) Obter uma lista de materiais de software (SBOM) e avaliar a exposição do componente vulnerável e a mitigação do fornecedor

B) Presumir que o fornecedor de hardware é totalmente responsável e não tomar nenhuma ação

C) Banir todo software de código aberto no ambiente

D) Solicitar que o fornecedor de hardware assine um acordo de confidencialidade

QUESTÃO 8 · CENÁRIO DE EXAME

Um provedor de nuvem se recusa a permitir uma avaliação no local, mas oferece seu relatório SOC 2. O contrato contém uma disposição que permite ao cliente verificar os controles do provedor. Qual é o melhor próximo passo?

A) Aceitar o relatório SOC 2 sem revisão porque auditorias no local nunca são permitidas

B) Revisar o relatório SOC 2 e, se necessário, invocar o direito contratual de auditoria para solicitar evidências adicionais

C) Realizar uma varredura externa de vulnerabilidades contra o provedor sem autorização

D) Encerrar o contrato imediatamente

QUESTÃO 9 · CENÁRIO DE EXAME

O relatório SOC 2 Tipo II de um fornecedor crítico cobre um período encerrado há 18 meses. O fornecedor não forneceu um relatório mais recente. O que a equipe de segurança deve fazer?

A) Ignorar a lacuna porque nenhuma violação foi relatada

B) Realizar um teste de penetração contra o fornecedor sem permissão

C) Solicitar um relatório SOC 2 atual ou uma carta ponte e reavaliar o risco do fornecedor

D) Remover o fornecedor do inventário de fornecedores

QUESTÃO 10 · CENÁRIO DE EXAME

Um contrato com um processador de dados terceirizado está terminando. Qual ação é mais importante para reduzir o risco de terceiros durante o offboarding?

A) Manter as credenciais do fornecedor ativas em caso de emergência

B) Excluir o fornecedor apenas da lista de contatos

C) Verificar se o acesso foi revogado e se os dados foram devolvidos ou destruídos com segurança conforme o contrato

D) Renovar o contrato sem alterações para evitar interrupções

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Cláusula de direito de auditoria

Uma cláusula de direito de auditoria concede à empresa contratante autoridade contratual para auditar ou avaliar os controles de segurança do fornecedor e obter evidências, algo essencial para o gerenciamento contínuo de risco de terceiros. Um NDA protege a confidencialidade, mas não concede direitos de auditoria. Um SLA trata de desempenho e disponibilidade. Um cronograma de retenção governa o ciclo de vida dos dados, não a verificação de controles.

Questão 2: Alternativa A — Avaliar o subprocessador como risco de quarta parte e solicitar evidências de seus controles

A análise da cadeia de suprimentos exige entender quem fornece o fornecedor. Um subprocessador não divulgado é um risco de quarta parte. A equipe deve identificá-lo, avaliar seus controles e determinar o impacto. Depender apenas do SOC 2 do fornecedor principal pode deixar lacunas de escopo. Encerrar o contrato imediatamente é desproporcional sem análise de risco. Um NDA não aborda controles de segurança.

Questão 3: Alternativa B — Monitorar notificações de violação, classificações de segurança e atestados atualizados do fornecedor

O monitoramento de fornecedores é contínuo e deve incluir inteligência externa de ameaças e violações, classificações de segurança, notícias e atestados atualizados, como relatórios SOC 2. A due diligence inicial fica desatualizada. Testes de penetração não autorizados são ilegais e antiéticos. Relatórios de disponibilidade não refletem a postura de segurança.

Questão 4: Alternativa C — Escopo, período de auditoria, exceções e controles complementares da entidade usuária

Um relatório SOC 2 Tipo II só é útil quando seu escopo cobre os serviços relevantes, o período de auditoria é atual, as exceções são compreendidas e os controles complementares da entidade usuária são implementados pelo cliente. Detalhes financeiros ou de vendas e duração do contrato não verificam controles de segurança.

Questão 5: Alternativa B — Acordo de confidencialidade

Um NDA é o acordo apropriado antes de divulgar informações internas sensíveis a um fornecedor em potencial. Ele limita legalmente o uso e a divulgação de dados confidenciais. Uma cláusula de direito de auditoria concede direitos de avaliação, mas não é primariamente para confidencialidade antes da divulgação. Um relatório SOC 2 é uma atestação, não um acordo. Uma BIA avalia interrupções nos negócios.

Questão 6: Alternativa D — Nível de acesso a dados sensíveis e criticidade para o negócio

A gestão de fornecedores baseada em risco prioriza fornecedores pela sensibilidade dos dados que acessam, seu acesso a sistemas e redes e quão críticos são para as operações. Localização, longevidade e condições de pagamento não medem diretamente o risco de segurança.

Questão 7: Alternativa A — Obter uma lista de materiais de software (SBOM) e avaliar a exposição do componente vulnerável e a mitigação do fornecedor

A análise da cadeia de suprimentos inclui dependências de software. Uma SBOM ajuda a identificar o componente vulnerável, sua versão, onde é usado e se o fornecedor tem patch ou mitigação. Presumir responsabilidade do fornecedor ignora o risco da organização. Banir todo código aberto é impraticável. Um NDA não aborda gerenciamento de vulnerabilidades.

Questão 8: Alternativa B — Revisar o relatório SOC 2 e, se necessário, invocar o direito contratual de auditoria para solicitar evidências adicionais

O cliente deve revisar primeiro o relatório SOC 2 e depois usar a cláusula contratual de direito de auditoria para obter evidências adicionais ou conduzir uma avaliação remota se houver lacunas. Aceitar sem revisão é negligente. Varreduras não autorizadas são ilegais. Encerrar imediatamente é desproporcional sem avaliar as evidências.

Questão 9: Alternativa C — Solicitar um relatório SOC 2 atual ou uma carta ponte e reavaliar o risco do fornecedor

Um relatório SOC 2 desatualizado não fornece garantia razoável sobre os controles atuais. A equipe deve solicitar um relatório atual ou uma carta ponte cobrindo a lacuna e reavaliar o risco. Nenhuma violação relatada não é prova de segurança. Testes não autorizados são ilegais. Remover o fornecedor do inventário não gerencia o risco se ele ainda é usado.

Questão 10: Alternativa C — Verificar se o acesso foi revogado e se os dados foram devolvidos ou destruídos com segurança conforme o contrato

O offboarding deve incluir revogação de todos os acessos, recuperação ou destruição segura dos dados e confirmação de que o fornecedor não retém mais dados da organização. Manter credenciais ativas cria risco. Excluir um contato é insuficiente. Renovar sem alterações pode não abordar o risco se o relacionamento está terminando.